

Introduction to Network Security

Roshan Chitrakar, PhD

Professor, NCIT

roshanchi@ncit.edu.np

Background

Information Security was provided, before digital age, in an organization by physical and administrative means
e.g. Filing cabinet with locking system, personnel screening at the time of recruitment etc.

With the introduction of computers, and development of shared systems, public telephone networks, data networks and the Internet, the term **Computer Security** was defined as *"A collection of tools designed to protect data and to thwart hackers"*.

Distributed systems and network/communication facilities give rise to the need of security measures to protect data during their transmission, and hence the term **Network security** was introduced.

Nowadays, most organizations interconnect their data processing equipments with inter-connected networks (i.e. Internet). So, the term **Internet security** is used.

Security Attacks

Passive attacks:

- ▮ attempt to learn or make use of information from the system but **does not affect system resources**

- ▮ are in the nature of **eavesdropping** (listening secretly to the private conversation) on, or **monitoring** of, **transmissions**.

- ▮ goal of the opponent is **to obtain information** that is being transmitted.

- ▮ Very **difficult to detect**, because they do not involve any alteration of the data. The message traffic is sent and received in an apparently normal fashion, and neither the sender nor receiver is aware that a third party has read the messages or observed the traffic pattern

- ▮ However, it is **feasible to prevent** the success of these attacks, usually by means of encryption

- ▮ e.g. **release of message contents** and **traffic analysis** etc.

Active attacks:

- ▮ attempt to **alter system resources** or **affect their operation**.

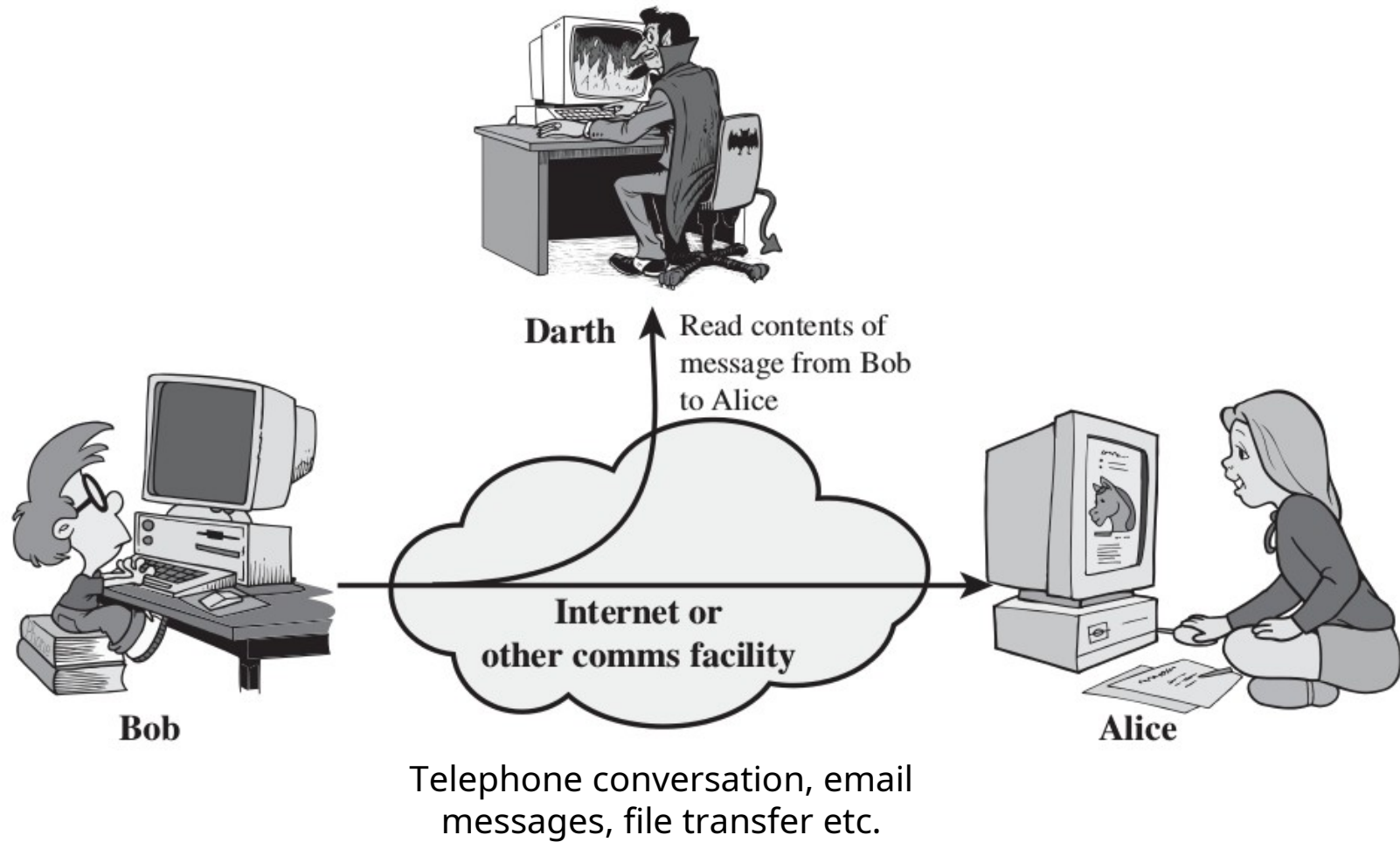
- ▮ involve some **modification of the data stream** or the **creation of a false stream**

- ▮ Active attacks are quite **difficult to be absolutely prevented** because of the wide variety of potential physical, software, and network vulnerabilities.

- ▮ The goal is **to detect active attacks and to recover from any disruption or delays** caused by them

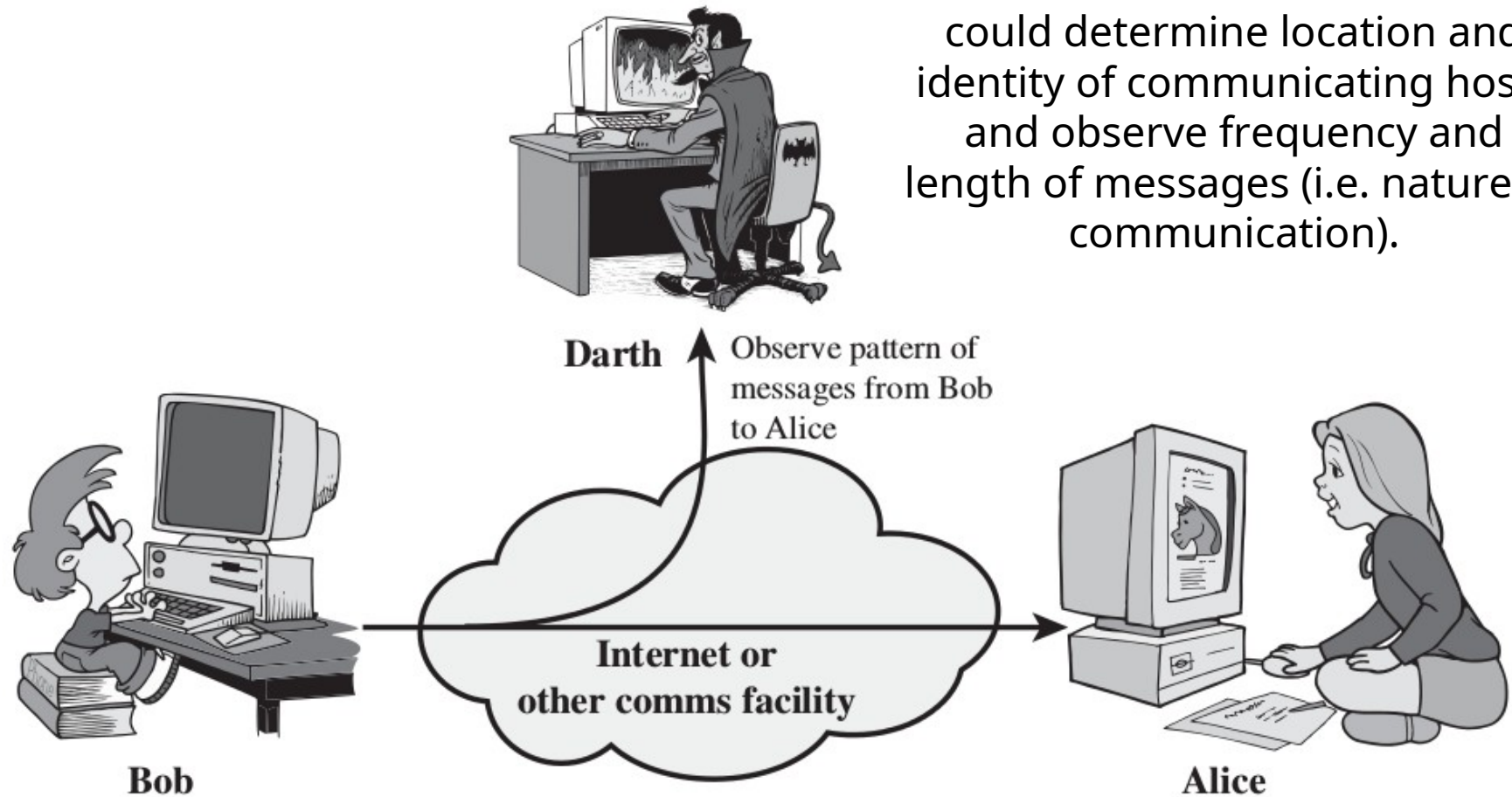
- ▮ e.g. **masquerade**, **replay**, **modification of messages**, **denial of service** etc.

Passive attack: Release of Message Contents



Passive attack: Traffic Analysis

could determine location and identity of communicating hosts and observe frequency and length of messages (i.e. nature of communication).



Active attack: Masquerade

(Impersonation of the entity that has privileges)



Darth

Message from Darth
that appears to be
from Bob

authentication sequences
can be captured to obtain
extra privileges and
replayed after a valid
authentication sequence
has taken place



Bob



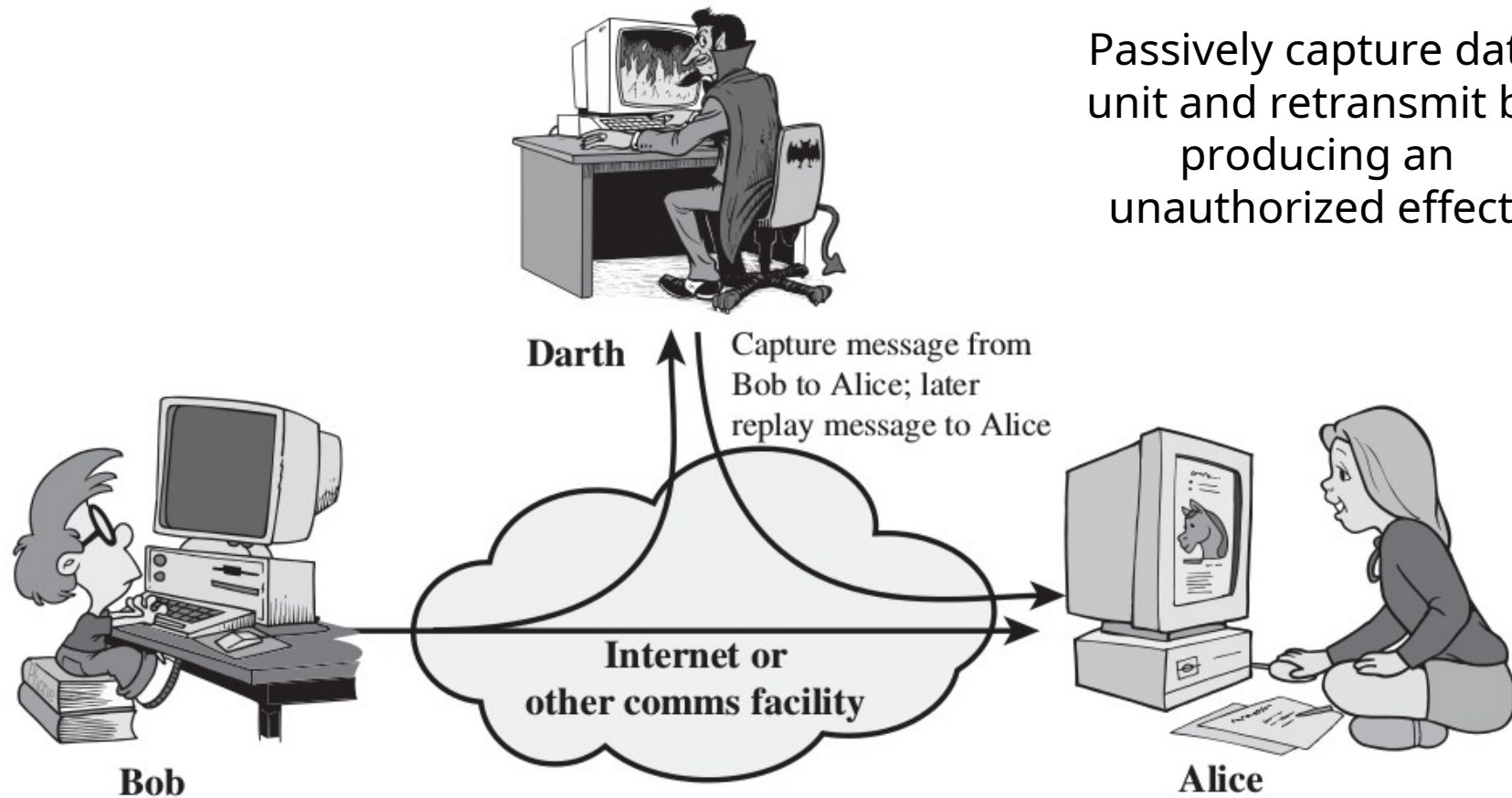
Internet or
other comms facility



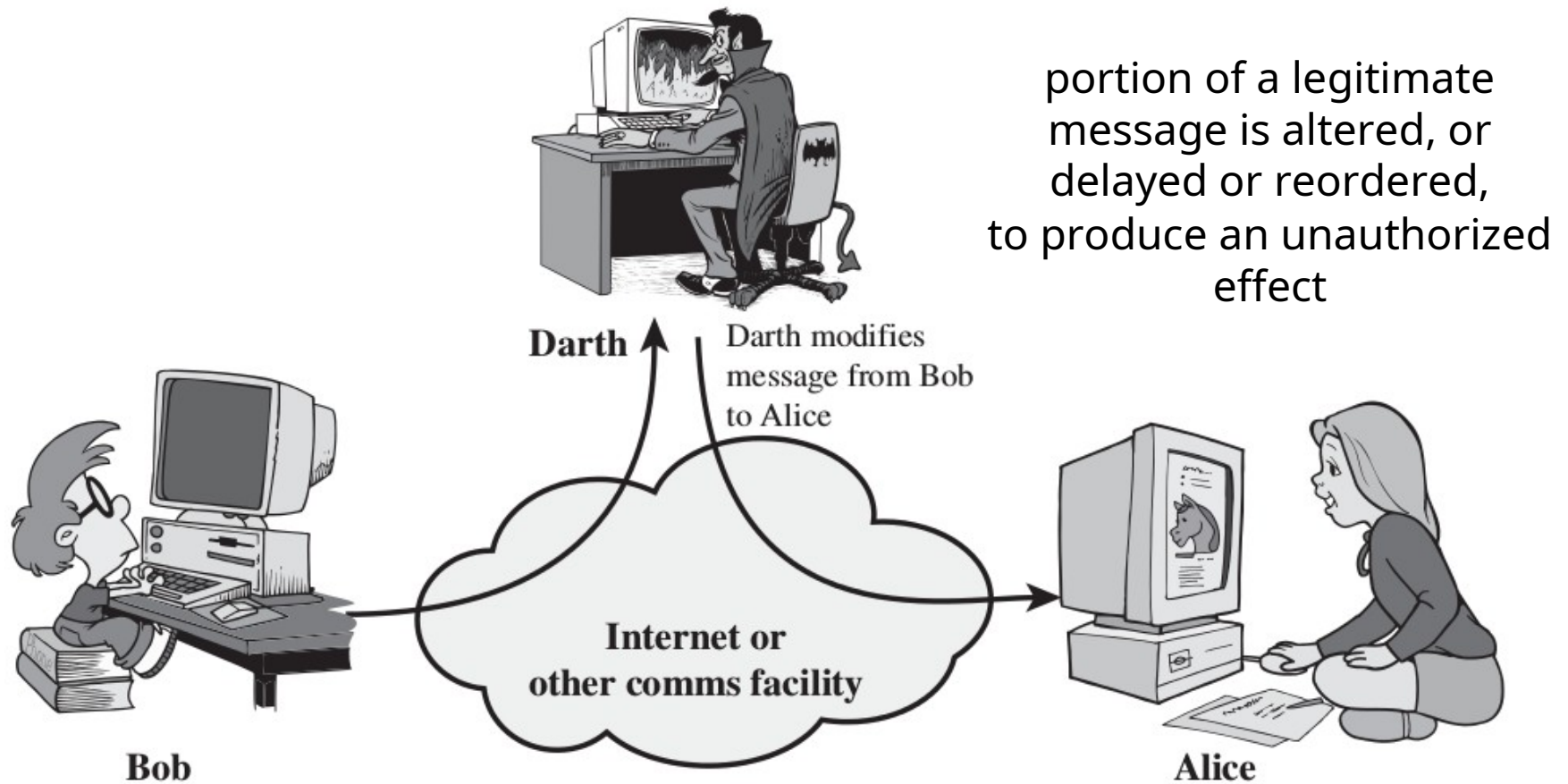
Alice

Active attack: Replay

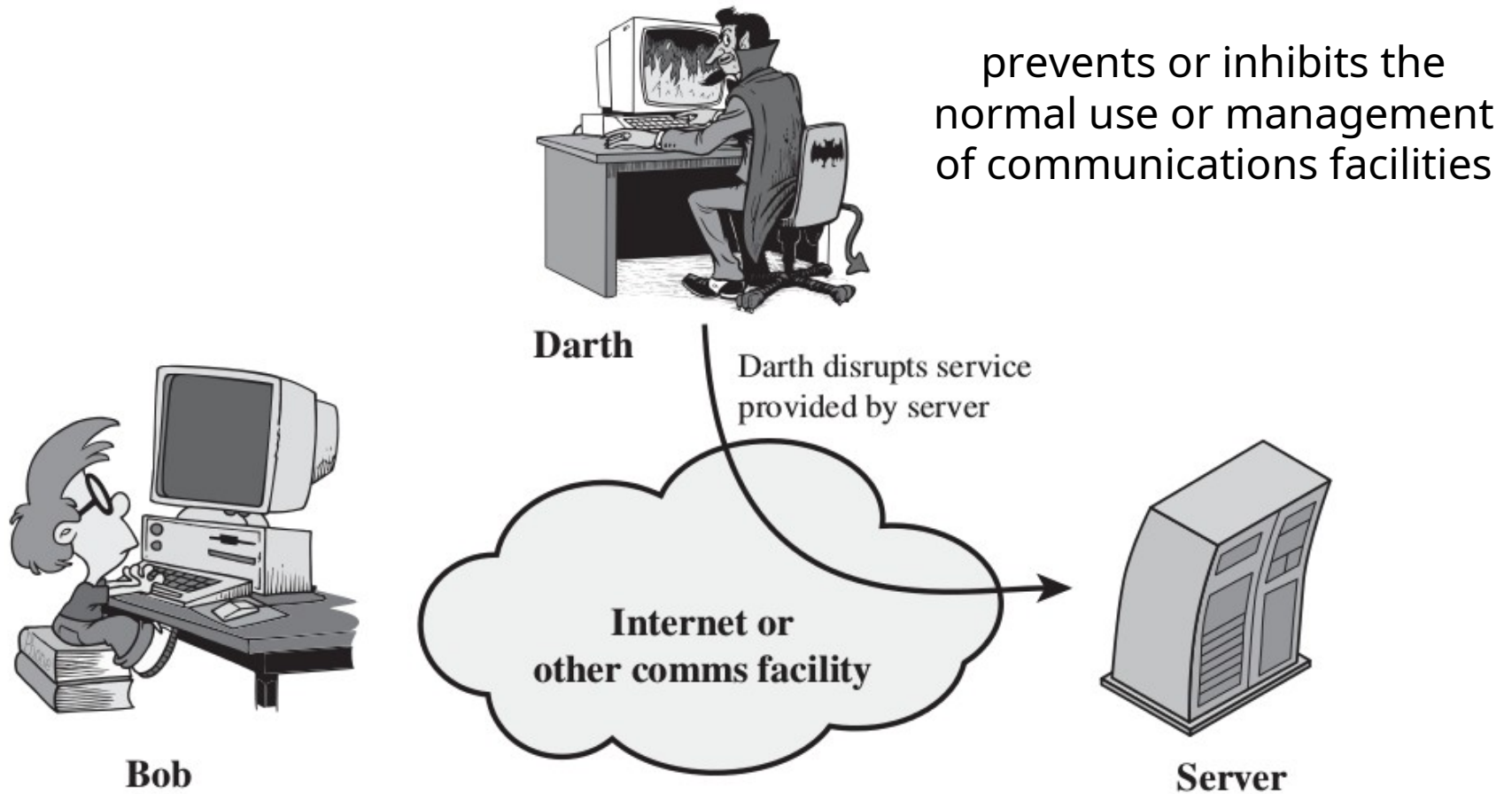
Passively capture data unit and retransmit by producing an unauthorized effect.



Active attack: Modification of Messages



Active attack: Denial of Service



Examples: -

- (1) an entity may suppress all messages directed to a particular destination
- (2) disable the whole network
- (3) overload the network with messages so as to degrade performance

Security Violation: Scenario #1

User A transmits a file to user B. The file contains sensitive information (e.g., payroll records) that is to be protected from disclosure. User C, who is not authorized to read the file, is able to monitor the transmission and capture a copy of the file during its transmission.

Security Violation: Scenario #2

A network manager, D, transmits a message to a computer, E, under its management. The message instructs computer E to update an authorization file to include the identities of a number of new users who are to be given access to that computer. User F intercepts the message, alters its contents to add or delete entries, and then forwards the message to computer E, which accepts the message as coming from manager D and updates its authorization file accordingly.

Security Violation: Scenario #3

(contd. from scen. #2)

Rather than intercepting a message, user F constructs its own message with the desired entries and transmits that message to computer E as if it had come from manager D. Computer E accepts the message as coming from manager D and updates its authorization file accordingly.

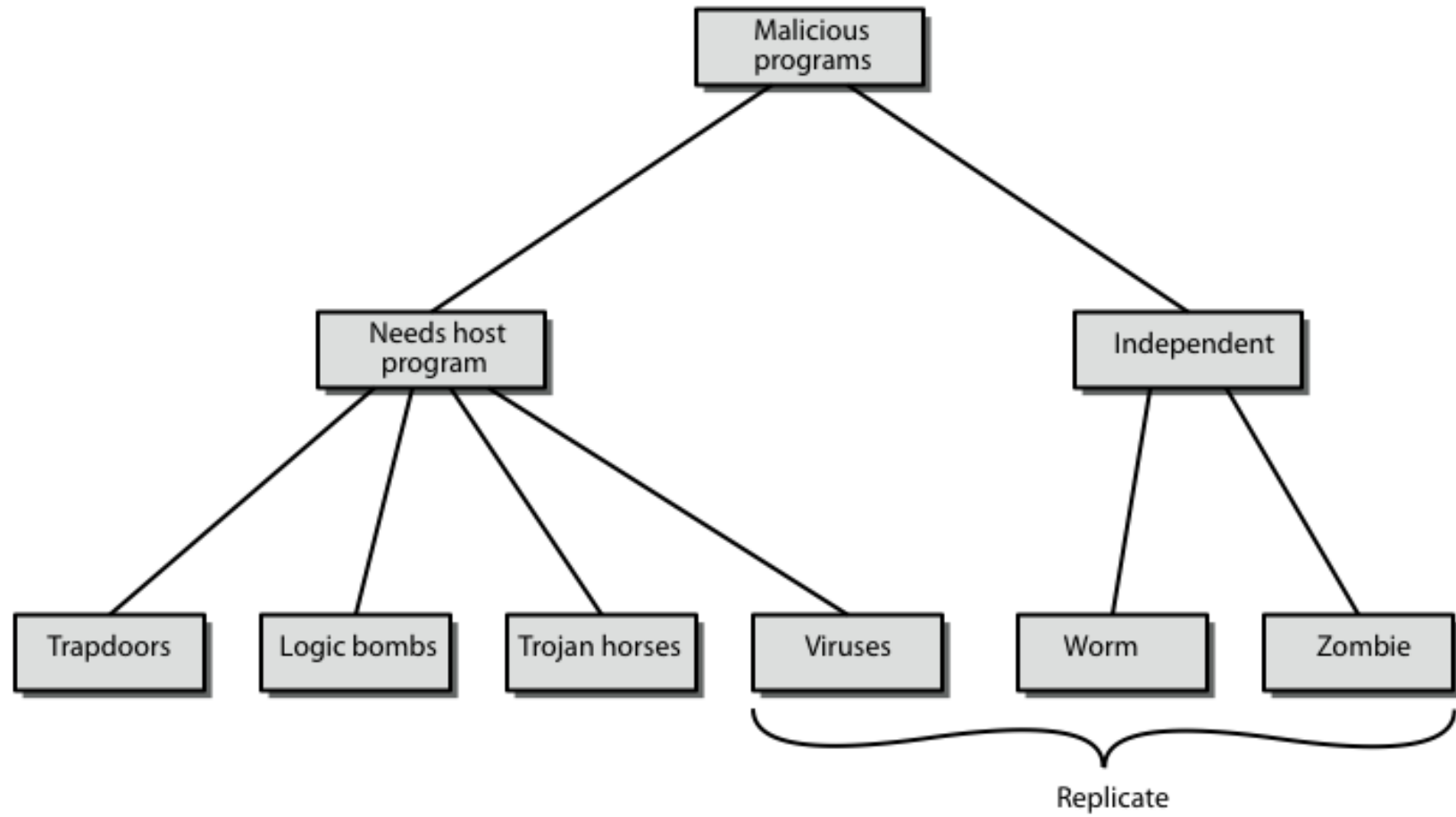
Security Violation: Scenario #4

An employee is fired without warning. The personnel manager sends a message to a server system to invalidate the employee's account. When the invalidation is accomplished, the server is to post a notice to the employee's file as confirmation of the action. The employee is able to intercept the message and delay it long enough to make a final access to the server to retrieve sensitive information. The message is then forwarded, the action taken, and the confirmation posted. The employee's action may go unnoticed for some considerable time.

Security Violation: Scenario #5

A message is sent from a customer to a stockbroker with instructions for various transactions. Subsequently, the investments lose value and the customer denies sending the message.

Malicious Software



Viruses

piece of software that infects programs

- modifying them to include a copy of the virus
- so it executes secretly when host program is run

specific to operating system and hardware

- taking advantage of their details and weaknesses

a typical virus goes through phases of:

- dormant
- propagation
- triggering
- execution

Virus Structure

- components:
 - infection mechanism - enables replication
 - trigger - event that makes payload activate
 - payload - what it does, malicious or benign
- prepended / postpende / embedded
- when infected program invoked, executes virus code then original program code
- can block initial infection (difficult)
- or propagation (with access controls)

Virus Classification

- boot sector
- file infector
- macro virus
- encrypted virus
- stealth virus
- polymorphic virus
- metamorphic virus

Virus Countermeasures and Anti-viruses

- prevention - ideal solution but difficult
- realistically need:
 - detection
 - identification
 - removal
- if detect but can't identify or remove, must discard and replace infected program
- virus & antivirus tech have both evolved
- early viruses simple code, easily removed
- as become more complex, so must the countermeasures
- generations
 - first - signature scanners
 - second - heuristics
 - Third - identify actions
 - fourth - combination packages

Worms

- replicating program that propagates over net
 - using email, remote exec, remote login
- has phases like a virus:
 - dormant, propagation, triggering, execution
 - propagation phase: searches for other systems, connects to it, copies self to it and runs
- may disguise itself as a system process
- concept seen in Brunner's "Shockwave Rider"
- implemented by Xerox Palo Alto labs in 1980's

Worm Attacks Examples

- Morris Worm
 - released by Robert Morris in 1988
 - cracking password file to use login/password to logon to other systems
- Code Red
 - July 2001 exploiting MS IIS bug
 - probes random IP address, does DDoS attack
- Code Red II variant includes backdoor
- SQL Slammer
 - early 2003, attacks MS SQL Server
- Mydoom
 - mass-mailing e-mail worm that appeared in 2004
 - installed remote access backdoor in infected systems
- Warezov family of worms
 - scan for e-mail addresses, send in attachment

Worm Technology

- multiplatform
- multi-exploit
- ultrafast spreading
- polymorphic
- metamorphic
- transport vehicles
- zero-day exploit

Trojan Horse

- program with hidden side-effects
- which is usually superficially attractive
 - e.g. game, s/w upgrade etc.
- when run, performs some additional tasks
 - allows attacker to indirectly gain access they do not have directly
- often used to propagate a virus/worm or install a backdoor
- or simply to destroy data

Intruders

- significant issue for networked systems is hostile or unwanted access
- either via network or local
- can identify classes of intruders:
 - masquerader
 - misfeasor
 - clandestine user
- varying levels of competence
- range
 - benign: explore, still costs resources
 - serious: access/modify data, disrupt system
- intruder techniques & behavior patterns constantly shifting, but have common features

Examples of Intrusion

- remote root compromise
- web server defacement
- guessing / cracking passwords
- copying viewing sensitive data / databases
- running a packet sniffer
- distributing pirated software
- using an unsecured modem to access net
- impersonating a user to reset password
- using an unattended workstation

Intrusion Techniques

- aim to gain access and/or increase privileges on a system
- often use system / software vulnerabilities
- key goal often is to acquire passwords
 - so then exercise access rights of owner
- basic attack methodology
 - target acquisition and information gathering
 - initial access
 - privilege escalation
 - covering tracks
- Password guessing and capture are the most common attacks

Hackers

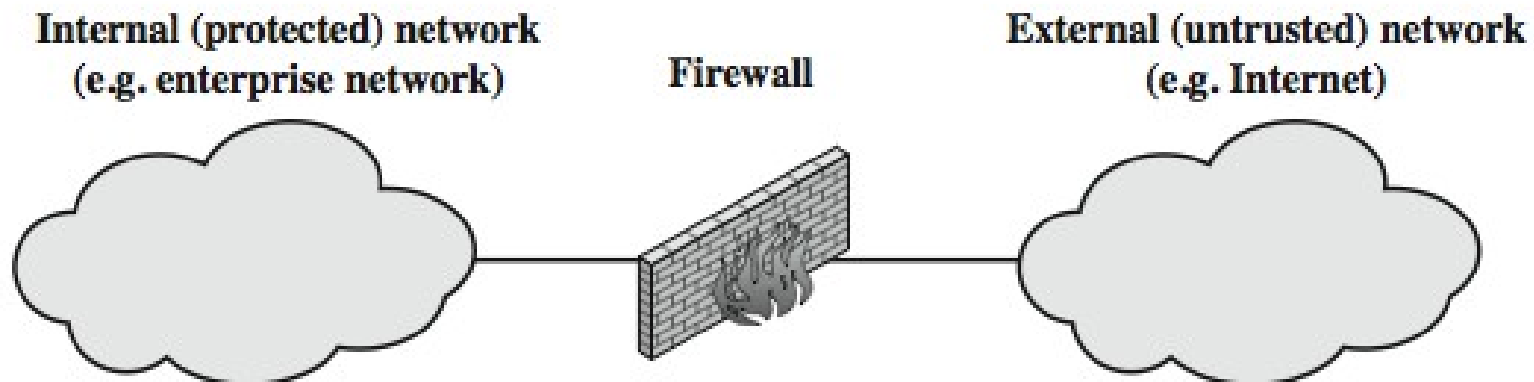
- motivated by thrill of access and status
 - hacking community a strong meritocracy
 - status is determined by level of competence
- hackers usually have specific targets
- often target credit cards on e-commerce server
- once penetrated act quickly and get out
- IDS / IPS / VPNs can help counter
- sensitive data needs strong protection

Hacker Behavior Example

1. select target using IP lookup tools
2. map network for accessible services
3. identify potentially vulnerable services
4. brute force (guess) passwords
5. install remote administration tool
6. wait for admin to log on and capture password
7. use password to access remainder of network

Firewall

- use a **Firewall** to provide **perimeter defence**
- as part of comprehensive security strategy
- a **choke point** of control and monitoring
- interconnects networks with differing trust
- imposes restrictions on network services
 - only authorized traffic is allowed
- auditing and controlling access
 - can implement alarms for abnormal behavior
- provide NAT & usage monitoring
- implement VPNs using IPSec
- must be immune to penetration

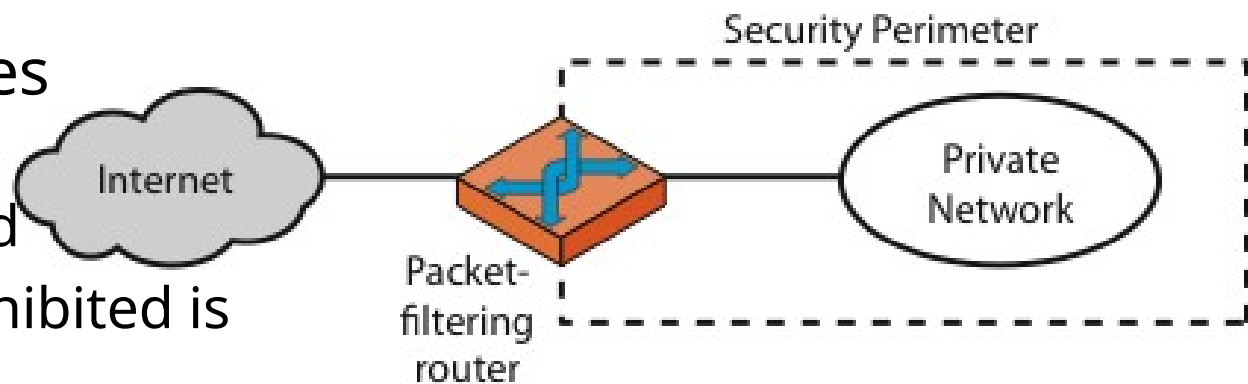
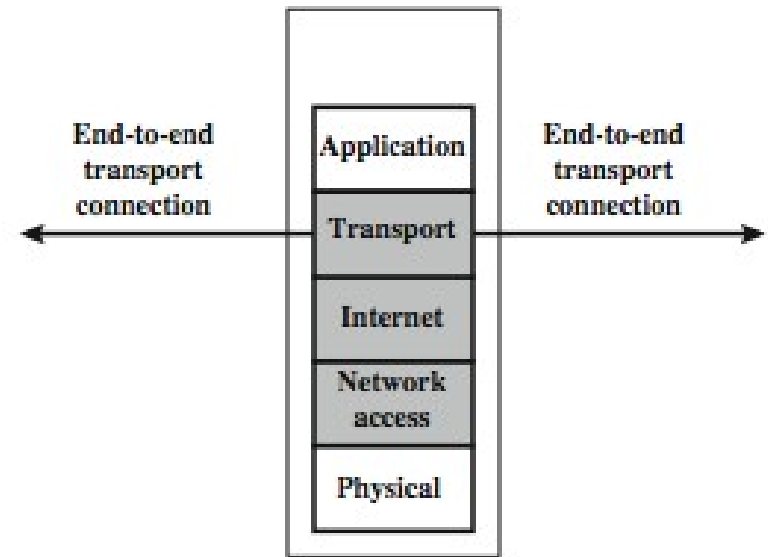


Firewall Limitations

- cannot protect from attacks bypassing it
 - eg sneaker net, utility modems, trusted organisations, trusted services (eg SSL/SSH)
- cannot protect against internal threats
 - eg disgruntled or colluding employees
- cannot protect against access via WLAN
 - if improperly secured against external use
- cannot protect against malware imported via laptop, PDA, storage infected outside

Firewalls – Packet Filters

- simplest, fastest firewall component
- foundation of any firewall system
- examine each IP packet (no context) and permit or deny according to rules
- hence restrict access to services (ports)
- possible default policies
 - that not expressly permitted is prohibited
 - that not expressly prohibited is permitted



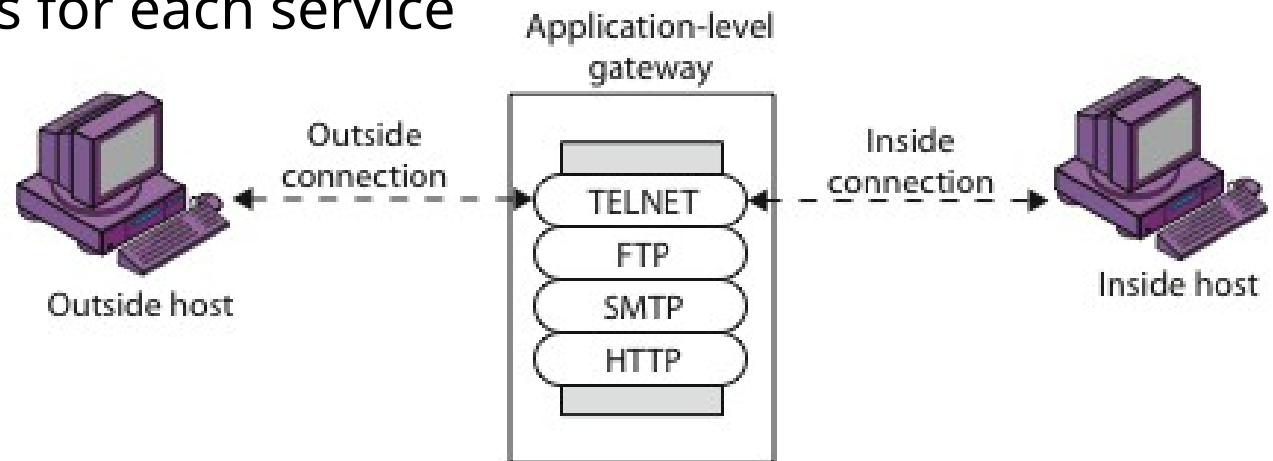
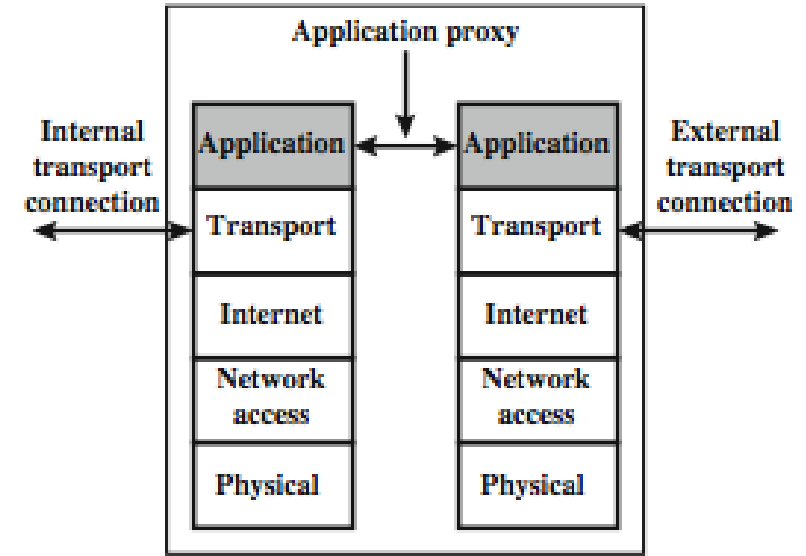
(a) Packet-filtering router

Firewalls – Stateful Packet Filters

- traditional packet filters do not examine higher layer context
 - ie matching return packets with outgoing flow
- stateful packet filters address this need
- they examine each IP packet in context
 - keep track of client-server sessions
 - check each packet validly belongs to one
- hence are better able to detect bogus packets out of context
- may even inspect limited application data

Firewalls - Application Level Gateway (or Proxy)

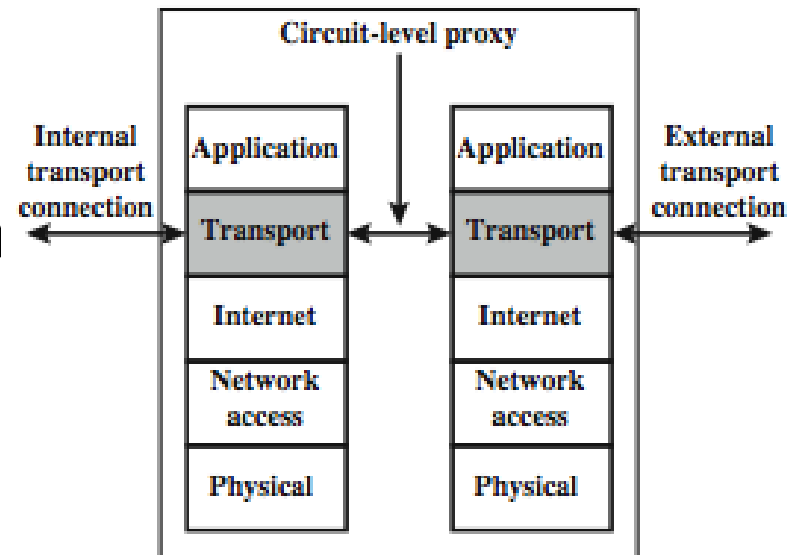
- have application specific gateway / proxy
- has full access to protocol
 - user requests service from proxy
 - proxy validates request as legal
 - then actions request and returns result to user
 - can log / audit traffic at application level
- need separate proxies for each service
 - some services naturally support proxying
 - others are more problematic



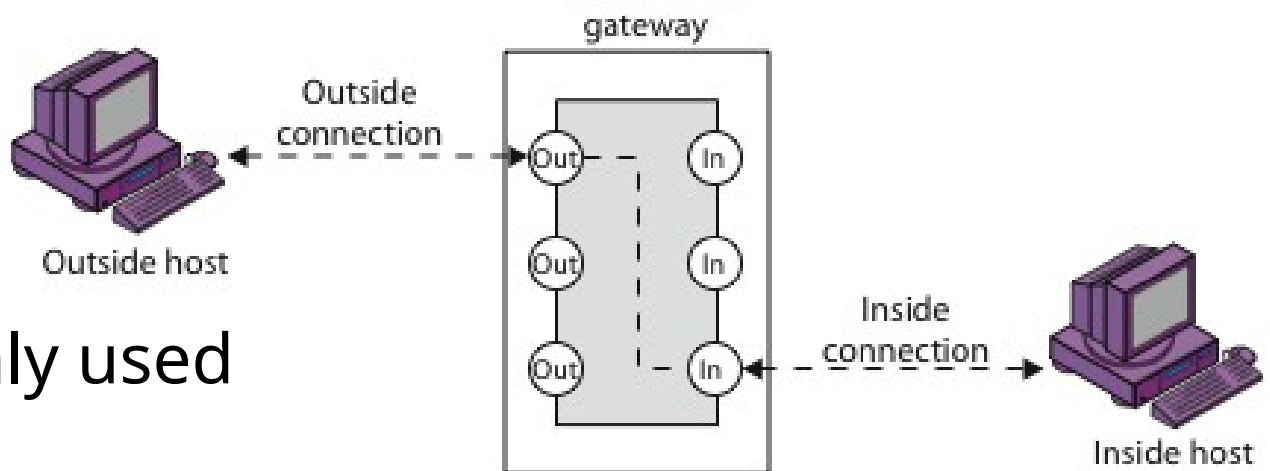
(b) Application-level gateway

Firewalls - Circuit Level Gateway

- relays two TCP connections
- imposes security by limiting which such connections are allowed
- once created usually relays traffic without examining contents
- typically used when trust internal users by allowing general outbound connections
- SOCKS is commonly used

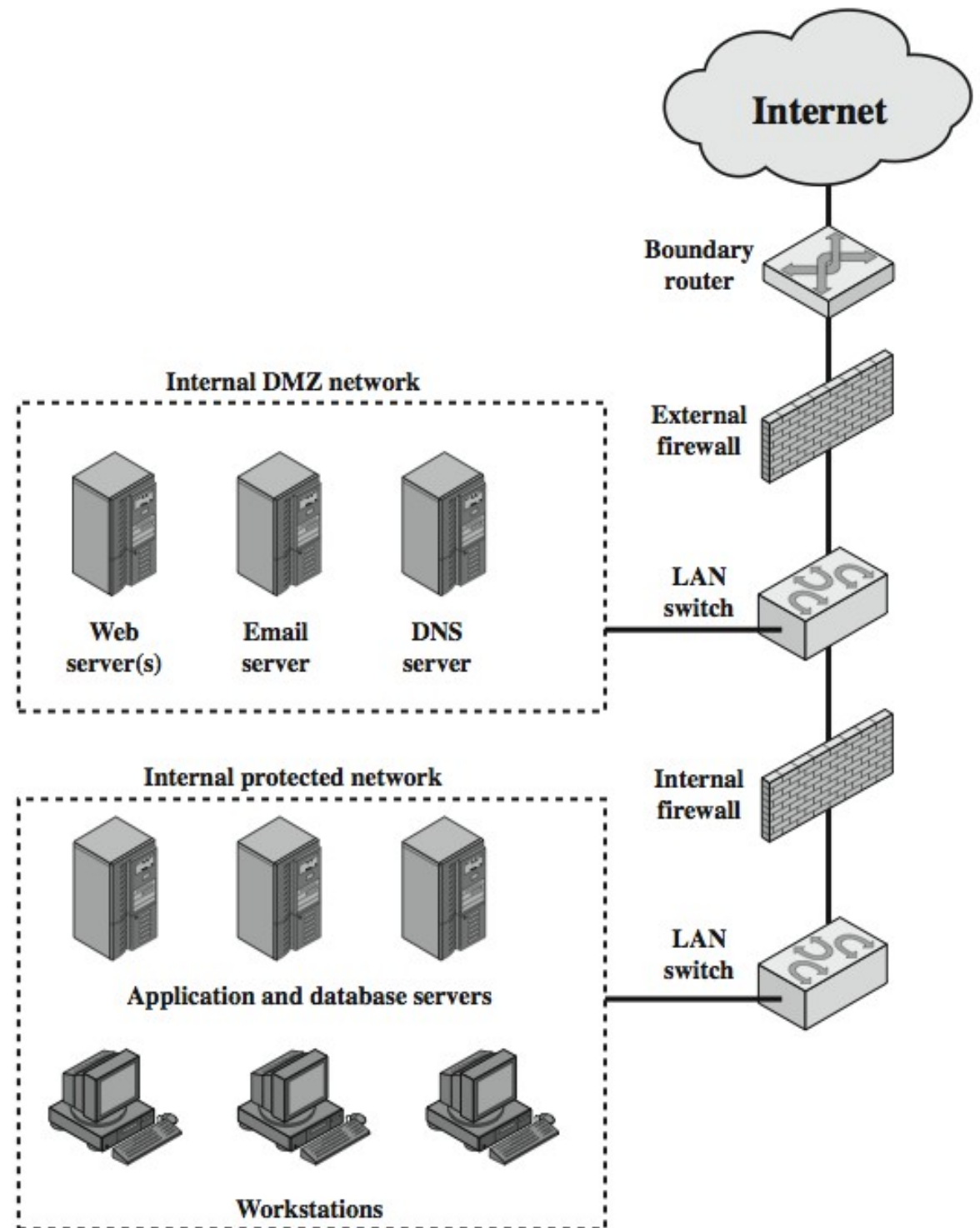


(e) Circuit-level proxy firewall



(c) Circuit-level gateway

DMZ Networks



Computer Security : Definition

The NIST Computer Security Handbook [NIST95] defines: -

- “The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability, and confidentiality of information system resources (*includes hardware, software, firmware, information/data, and telecommunications*).”

¶ This definition introduces three key concepts, collectively called CIA Triad: -

- Confidentiality
- Integrity
- Availability

¶ Security characteristics have also been set on the basis of these objectives.

The CIA Triad: Objectives

The CIA triad embodies the fundamental security objectives for both data and for information and computing services.

• **Confidentiality**: covers two concepts:

• Data confidentiality:

- Assures that private or confidential information is not made available or disclosed to unauthorized individuals.

• Privacy:

- Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.

• **Integrity**: covers two concepts:

• Data integrity:

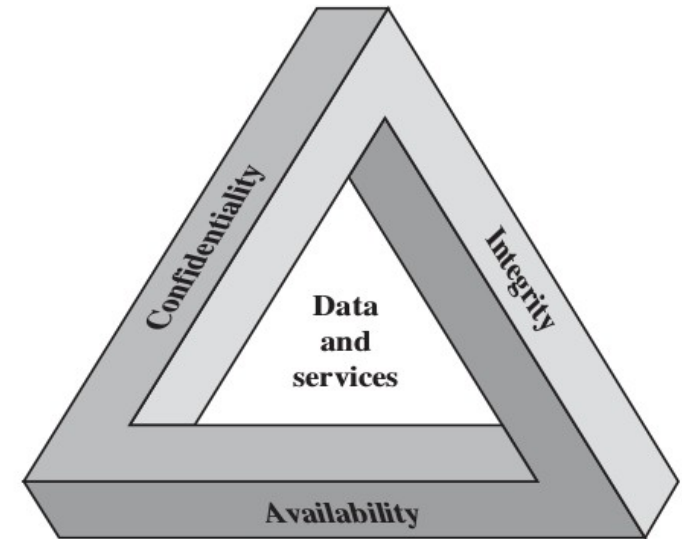
- Assures that information and programs are changed only in a specified and authorized manner.

• System integrity:

- Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.

• **Availability**:

- Assures that systems work promptly and service is not denied to authorized users.



CIA Triad: Security Characteristics

(FIPS 199 provides characterization and the definition of a loss of security in each category.)

Confidentiality:

- Preserving authorized restrictions on information access and disclosure
- includes means for protecting personal privacy and proprietary information
- *A loss of confidentiality is the unauthorized disclosure of information.*

Integrity:

- Guarding against improper information modification or destruction
- includes ensuring information non-repudiation and authenticity.
- *A loss of integrity is the unauthorized modification or destruction of information.*

Availability:

- Ensuring timely and reliable access to and use of information. A loss of availability is the disruption of access to or use of information or an information system.

Additional concepts: -

•Authenticity:

- The property of being genuine and being able to be verified and trusted,

•Accountability:

- The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity.

Security Services

▮ **X.800 definition:** A security service is a service that is provided by a protocol layer of communicating open systems and that ensures adequate security of the systems or of data transfers.

▮ **RFC 2828 definition:** A security service is a processing or communication service that is provided by a system to give a specific kind of protection to system resources.

▮ Security services implement security policies and are implemented by security mechanisms.

▮ Security services are divided into five categories and fourteen specific services.

AUTHENTICATION	ACCESS CONTROL	DATA CONFIDENTIALITY	DATA INTEGRITY	NONREPUDIATION
<i>1. Peer Entity Authentication 2. Data-Origin Authentication</i>	<i>3. Access Control</i>	<i>4. Connection Confidentiality 5. Connectionless Confidentiality 6. Selective-Field Confidentiality 7. Traffic-Flow Confidentiality</i>	<i>8. Connection Integrity with Recovery 9. Connection Integrity without Recovery 10. Selective-Field Connection Integrity 11. Connectionless Integrity 12. Selective-Field Connectionless Integrity</i>	<i>13. Nonrepudiation, Origin 14. Nonrepudiation, Destination</i>

Security Mechanisms

- ▮ Security mechanisms implement security services.
- ▮ Security mechanisms are divided into
 - ▮ those that are implemented in a specific protocol layer, such as TCP or an application-layer protocol, and
 - ▮ those that are not specific to any particular protocol layer or security service.

SPECIFIC SECURITY MECHANISMS	PERVASIVE SECURITY MECHANISMS
Encipherment Digital Signature Access Control Data Integrity Authentication Exchange Traffic Padding Routing Control Notarization	Trusted Functionality Security Label Event Detection Security Audit Trail Security Recovery
These mechanisms may be incorporated into the appropriate protocol layer in order to provide some of the OSI security services	These mechanisms are not specific to any particular OSI security service or protocol layer.

Relationship between Security Services and Security Mechanisms

Mechanism

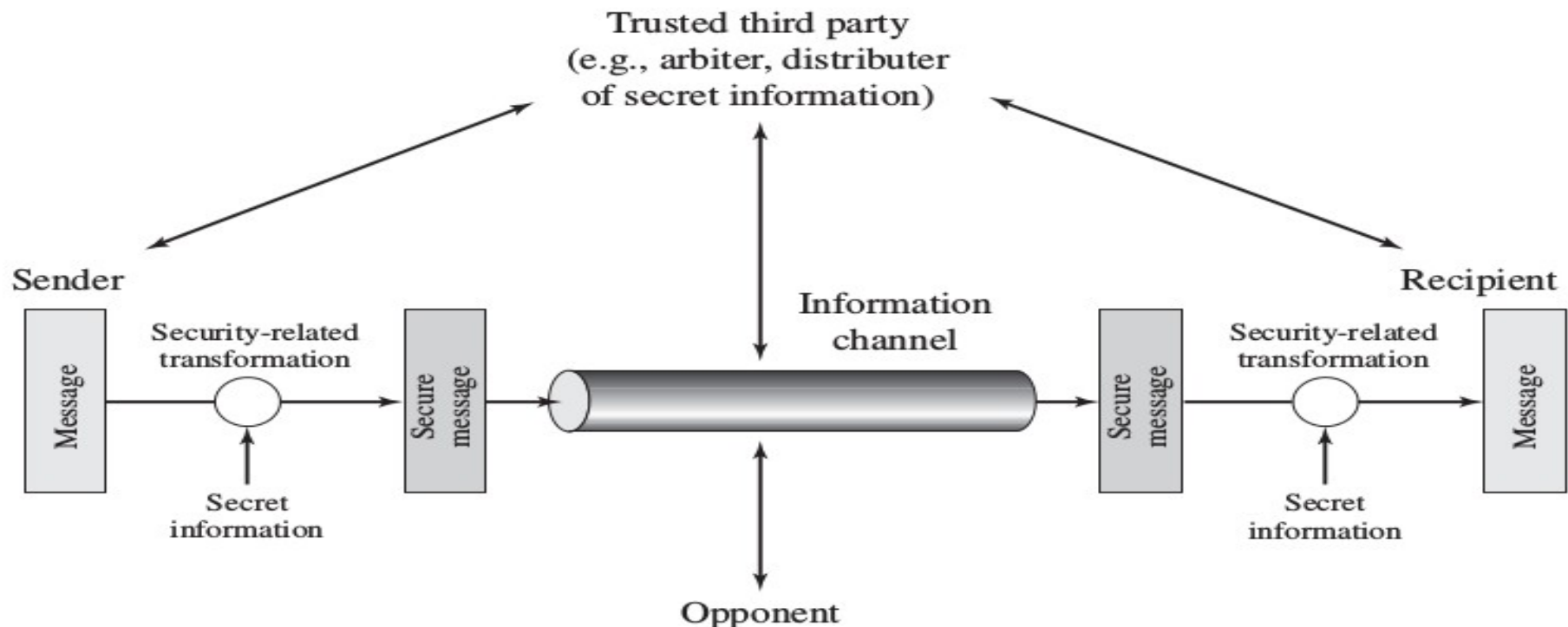
Service	Encipherment	Digital Signature	Access Control	Data Integrity	Authentication Exchange	Traffic Padding	Routing Control	Notarization
Peer Entity Authentication	Y	Y			Y			
Data Origin Authentication	Y	Y						
Access Control			Y					
Confidentiality	Y						Y	
Traffic Flow Confidentiality	Y					Y	Y	
Data Integrity	Y	Y		Y				
Nonrepudiation		Y		Y				Y
Availability				Y	Y			

A Network Security Model

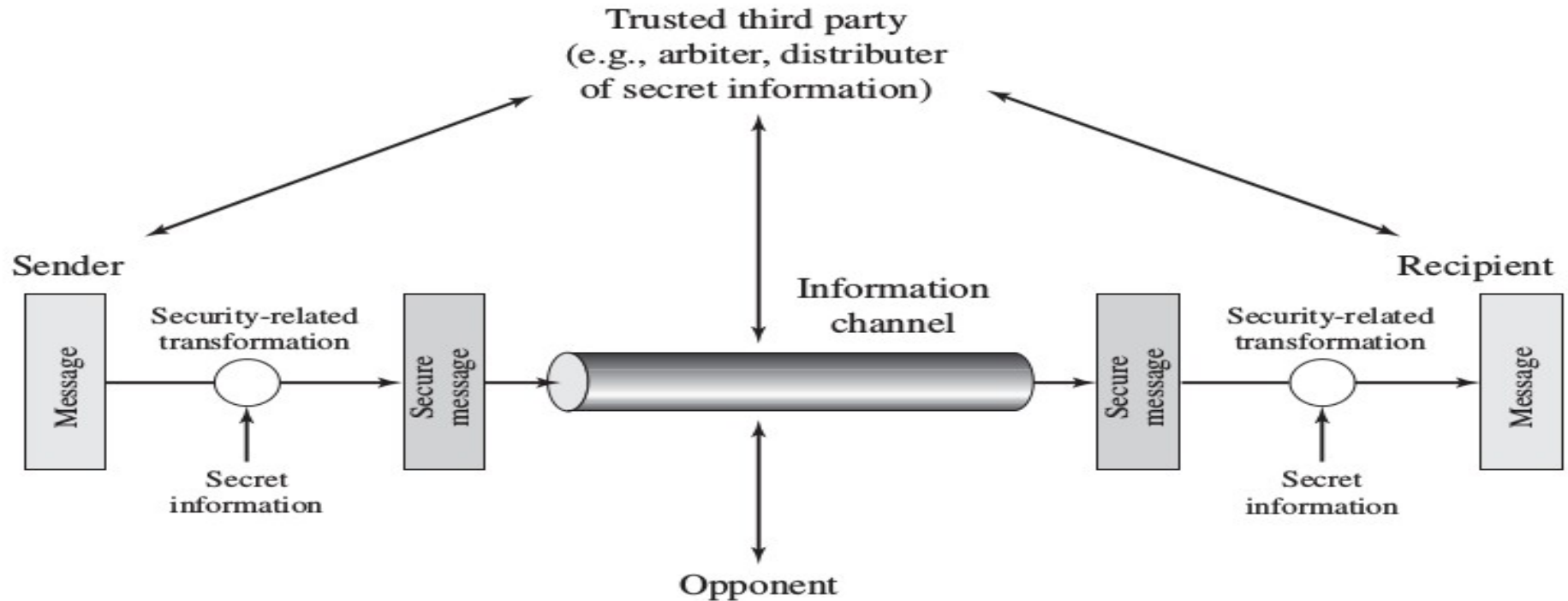
▮ Scenario:

▮ A **message** is to be **transferred** from one party to another (called **principals**) across some sort of Internet service (through a **logical information channel**) by the cooperation of a **communication protocol** (e.g. TCP/IP)

▮ It is necessary to **protect** the information transmission from an **opponent** who may present a **threat** to confidentiality, authenticity etc.



A Network Security Model



Techniques for providing security have **two** components: -

1. **A security-related transformation on the information to be sent** e.g.

- encryption of the message so make it unreadable by the opponent,
- addition of a code based on the contents to verify the identity of the sender.

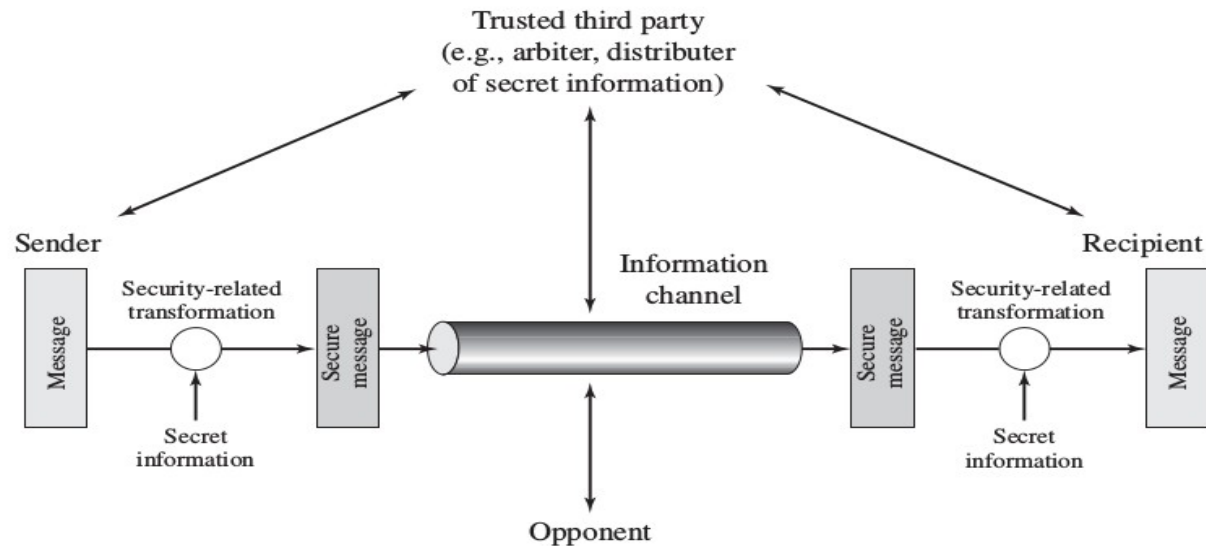
2. **Some secret information shared by the two principals only** e.g.

- an encryption key used along with the transformation to scramble the message before transmission and to unscramble it on reception.

A trusted third party may be needed to achieve secure transmission e.g.

- distributing the secret information to the two principals
- Settlement of disputes between two principals about the transmission authenticity.

A Network Security Model (contd.)

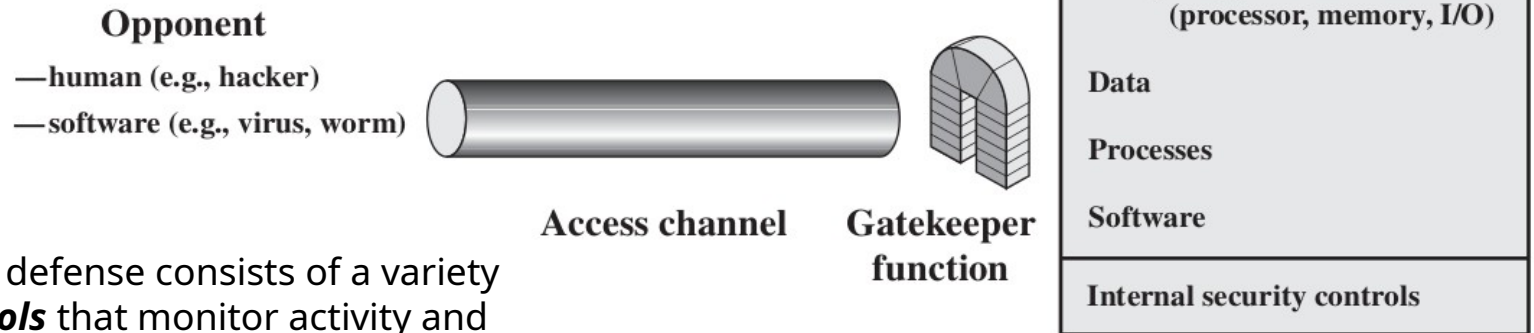


This model suggests **four basic tasks** in designing a security service:

- 1. Design an **algorithm** for performing the security-related transformation.
- 2. Generate the **secret information** to be used with the algorithm.
- 3. Develop **methods for the distribution** and sharing of the secret information.
- 4. Specify a **protocol** for the use of the security algorithm and the secret information.

Other model: Network Access Security Model

1. **Gatekeeper** includes password-based login procedures that are designed to deny access to all but authorized users and screening logic that is designed to detect and reject worms, viruses, and other similar attacks.



2. The second line of defense consists of a variety of **internal controls** that monitor activity and analyze stored information in an attempt to detect the presence of unwanted intruders.

- This model **reflects a concern for protecting an information system from unwanted access** like
 - Hackers' attempt to penetrate systems that can be accessed over a network
 - Intruders' wish to do damage or exploit computer assets for financial gain
 - placement of a logic that exploits vulnerabilities in the system and affects application and/or utility programs.